

CÓMO CREAR UN PROGRAMA DE PRIVACIDAD Y PROTECCIÓN DE DATOS

Manual práctico y conciso de implementación

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Propósito

Use este manual para trabajo legal, autorizado y defensivo. Adapte los controles al riesgo, las obligaciones legales, la accesibilidad y los recursos disponibles.

Gobierno y alcance

- Asigne liderazgo responsable y funciones entre legal, seguridad, datos, producto, RR. HH., compras y operaciones.
- Identifique leyes, contratos, jurisdicciones y expectativas regulatorias.
- Use asesoría legal competente para interpretación específica.

Inventario y mapas de datos

- Registre categorías, titulares, propósito, fuente, sistemas, ubicaciones, destinatarios, transferencias, retención y propietario.
- Incluya datos estructurados, documentos, registros, copias, analítica, instrucciones de IA, modelos y proveedores.
- Mantenga mapas mediante gestión de cambios.

Propósito, minimización y transparencia

- Recopile solo lo necesario para un propósito definido.
- Proporcione avisos claros y evite consentimiento engañoso.
- Evite usos secundarios incompatibles sin revisión y autoridad.

Derechos de titulares

- Cree flujos verificados y accesibles para acceso, corrección, eliminación, oposición, portabilidad y apelación cuando apliquen.
- Busque en sistemas y proveedores pertinentes.
- Controle plazos, decisiones, excepciones y evidencia.

Ingeniería de privacidad y seguridad

- Aplique privacidad desde requisitos hasta retiro.
- Use acceso, cifrado, tokenización, enmascaramiento, aislamiento, registros y eliminación segura.
- Evalúe reidentificación e inferencia.

Proveedores, transferencias e IA

- Revise encargados, subencargados, contratos, transferencias, incidentes, eliminación y auditoría.
- Evalúe entrenamiento, retención de prompts, perfiles, decisiones automatizadas, sesgo, transparencia y supervisión humana.
- Prohíba datos sensibles en herramientas no aprobadas.

Incidentes, métricas y hoja de ruta

- Integre evaluación de brechas de privacidad con respuesta a incidentes.
- Mida inventario, solicitudes vencidas, retención, evaluaciones de alto riesgo, proveedores e incidentes.
- Días 1-30: gobierno y mapa de alto riesgo. Días 31-60: derechos, retención, contratos y evaluaciones. Días 61-90: automatización, pruebas, métricas y revisión.

Lista de implementación

- ☐ Responsable asignado
- ☐ Alcance aprobado
- ☐ Inventario completo
- ☐ Riesgos priorizados
- ☐ Políticas documentadas
- ☐ Controles implementados
- ☐ Evidencia conservada
- ☐ Excepciones con vencimiento
- ☐ Pruebas completadas
- ☐ Revisión directiva registrada

Referencias oficiales

- NIST Privacy Framework 1.1: <https://www.nist.gov/privacy-framework/privacy-framework>
- Using Privacy Framework 1.1: <https://www.nist.gov/privacy-framework/using-privacy-framework-11>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.